2026 SHENZHEN INTERNATIONAL FINTECH COMPETITION
International Track, Artificial Intelligence, Topic F: Agent Wallet

Tameng

a guarded AI wallet agent for cross-border remittances

TECHNICAL DOCUMENTATION

Field	Information
Project Name	Tameng
Competition Track	Topic F: Agent Wallet (Autonomous On-Chain Participant)
Problem Domain	Cross-Border Remittances, Phishing, and Indirect Prompt Injection
Target Network & Asset	Base Sepolia Testnet, USDC (ERC-20, 6 decimals)
Team Name	Larpathon
Institution	Diponegoro University (UNDIP), Indonesia
Team Leader	Muhammad Faris Revansyah
Team Members	Muhammad Faris Revansyah, Habib Mukhlis Triatmojo, Farrel Adhi Pratama, Hizkia Yosefha Wetrawatri Sanjaya, Faras Fauzan Attaqi
Contact Email	farisrevan13@gmail.com
Repository	https://github.com/Htech5/TAMENGWALLET
Submission Date	20 October 2026

Submitted to: fintechathon@ican-x.com, Shenzhen, China, October 2026

Document Control

Attribute	Details
Document Identifier	TAMENG-TECH-DOC-V1.0
Status	Final v1.0
Team Name	Larpathon
Lead Architect / Contact	Muhammad Faris Revansyah (farisrevan13@gmail.com)
Technical Contributors	Muhammad Faris Revansyah (Mobile), Habib Mukhlis Triatmojo (Policy and Backend), Farrel Adhi Pratama (On-chain), Faras Fauzan Attaqi (Agent), Hizkia Yosefha Wetrawatri Sanjaya (Docs and Pitch)
Source Branch	main
Commit Reference	388b1067737f660c17eadb497dff21c396259cb1
Verification Status	120 automated checks passing (node --test); 11 on-chain transfers verified

Executive Proposal Summary

Tameng is an AI wallet agent (Topic F, Agent Wallet) that sends cross-border remittances autonomously while staying inside a mandate set by its owner. Indonesian migrant workers sent around Rp288 trillion (roughly US$17.5 billion) home in 2025 and still pay around 5.1% per transfer; they are also frequent targets of payment-diversion scams, and on-chain mistakes cannot be reversed. With Tameng, an owner sets a standing mandate once, for example 60 USDC to their mother, 20 to a sibling and 20 to savings every month, and the agent executes it on Base Sepolia without further input. Every transaction passes a policy layer written in code, not in the prompt. An intent check compares the decoded transaction with what the owner actually asked for, a provenance guard prevents tool outputs, token names or decoded text from ever triggering a transfer, look-alike address detection blocks address poisoning, and spending limits, allowlists and human confirmation cover the rest. We demonstrate the system against replicas of real attacks, including the May 2026 Morse-code prompt injection that drained an AI-linked wallet, and report results from an automated attack benchmark.

Keywords: Autonomous Agent Wallet, FinTech Security, Prompt Injection Mitigation, Cross-Border Remittances, On-Chain Verification, Deterministic Policy Engine.

Table of Contents

Document Control....2
Executive Proposal Summary....2
Table of Contents....3
Chapter 1: Introduction....5
1.1. The Real-World Problem: Remittance Overhead and Payment Diversion....5
1.2. The Autonomous Dilemma: Convenience Versus Vulnerability....5
1.3. Project Objectives and Boundary Constraints....5
1.4. Positioning: Before vs. After....6
Chapter 2: System Architecture and Data Flow....7
2.1. End-to-End Topology....7
2.2. Modular Component Taxonomy....7
2.3. Transaction Lifecycle and Two-Stage Policy Evaluation....8
Chapter 3: Core Security Algorithms....9
3.1. Intent Parsing and the Amount-as-null Convention....9
3.2. Deterministic Policy Engine (checkPolicy)....9
3.3. Look-alike and Injection Detection....10
3.4. Calldata Disassembly and Intent Equivalence....10
3.5. LLM Intent Reader and Grounding Guards....10
Chapter 4: Security Architecture and Threat Modeling....12
4.1. Threat Catalogue and Residual Risk....12
4.2. Key and Secret Management....12
Chapter 5: Implementation and Technology Stack....13
5.1. Runtime and Testing....13
5.2. Data Model and Repository Layout....13
Chapter 6: Empirical Evaluation and Attack Benchmark....14
6.1. Acceptance Criteria (AC-01 to AC-10)....14

6.2. Attack Benchmark Results....14
Chapter 7: Limitations and Future Roadmap....16
7.1. Acknowledged Limitations....16
7.2. Engineering Roadmap....16
Chapter 8: Conclusion....17
Appendix A: Official Submission Checklist....18
Appendix B: Domain Glossary....18
Appendix C: Evidence Index....18

Chapter 1: Introduction

1.1. The Real-World Problem: Remittance Overhead and Payment Diversion

Indonesian migrant workers sent Rp288 trillion (roughly US$17.5 billion) home in 2025. Despite the aggregate volume, each transfer still carries a corridor cost of about 5.13% (World Bank RPW Q3 2025), eroding funds intended for household needs and education.

Beyond high fees, migrant families are frequent targets of payment-diversion fraud, clipboard address replacement, and phishing. On a public ledger, a mistaken or coerced transaction is irreversible, which makes automated protection a necessity.

The May 2026 incident made this risk concrete where an attacker embedded a Morse-code message within a prompt, tricking Grok's Bankr bot into transferring about US$150,000 to 200,000 (figures vary across sources) in tokens from a verified wallet (documented in the OECD AI Incidents Monitor at oecd.ai/en/incidents/2026-05-04-4a73 and the AI Incident Database at incidentdatabase.ai/cite/1556/). To address this specific threat vector, the team reproduces this obfuscation method in the attack benchmark, ensuring Morse-encoded transfer instructions are correctly decoded and subsequently refused.

1.2. The Autonomous Dilemma: Convenience Versus Vulnerability

Language-model agents make recurrent family transfers convenient, because the owner can state a mandate once in natural language. That convenience is also what makes it dangerous: if the model can reach the signing key, then text it reads from tool outputs, token names, or forwarded messages can steer it toward unauthorized transfers through indirect prompt injection.

1.3. Project Objectives and Boundary Constraints

Tameng fulfills four operational objectives:

1. Unattended Mandate Execution: run scheduled family transfers within user-defined bounds.
2. Non-Circumventable Policy Guardrails: enforce deterministic policy checks independent of model reasoning.
3. Calldata Disassembly Verification: compare decoded calldata against the card the user confirmed.

4. Anomaly Neutralization: intercept look-alike addresses and obfuscated adversarial input.

1.4. Positioning: Before vs. After

Table 1.1: Comparative positioning

Evaluation Dimension	Conventional Web3 Wallet	Generic LLM Trading Bot	Tameng Protective Agent
Execution Mode	Manual click and sign	Unconstrained automated	Autonomous within strict Mandate
Injection Resistance	Not applicable	Vulnerable to jailbreak	Deterministic via Provenance Tagging
Calldata Inspection	Raw hex strings	Blind execution	Decoded and compared to confirmed card
Address Poisoning	Visual user inspection	Blind address resolution	Prefix and suffix collision block
Approval Security	Unlimited allowance trap	Arbitrary contract approve	Unlimited allowance denied
Corridor Fee	Traditional spread	Exchange gas fees	Sub-cent Layer-2 gas (Base Sepolia)

Chapter 2: System Architecture and Data Flow

2.1. End-to-End Topology

The Expo mobile app calls a single Node server that runs without a build step and without a web framework. That server connects three modules: agent/ converts a message into an intent, policy/ decides whether the intent is allowed, and onchain/ executes the transfer. Only the server talks to the language model and to the chain; the phone only sends requests and approvals over REST.

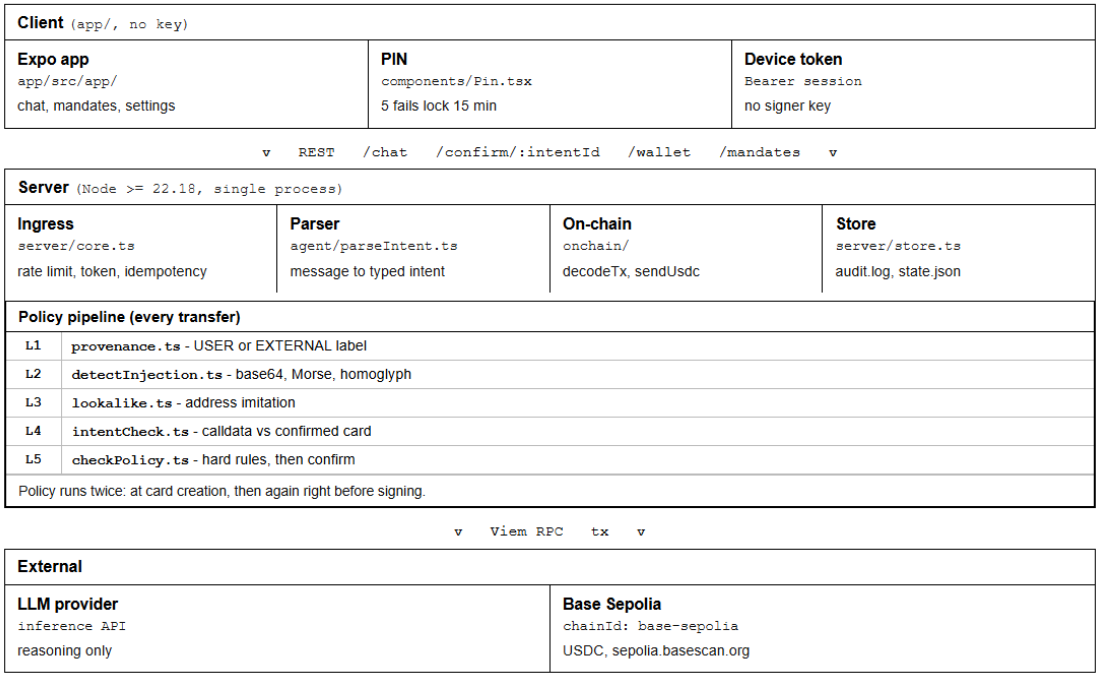


Figure 2.1: System topology - mobile app, single Node server, agent/policy/onchain modules, Base Sepolia

2.2. Modular Component Taxonomy

Table 2.1: Component taxonomy and trust boundaries

Component	Location	Primary Responsibility	Trust Level
Mobile App	app/	Captures mandates, renders decision cards, PIN and biometric prompts	Untrusted
Intent Parser	agent/parseIntent.ts	Converts message into typed intent; rules first, LLM tool-calling only when the rules are unsure	Semi-Trusted
Provenance Layer	policy/provenance.ts	Labels text USER or EXTERNAL; forwarded-text orders are never the owner speaking	Enforcement

Component	Location	Primary Responsibility	Trust Level
Injection Detector	policy/ detectInjection.ts	Flags obfuscated instructions (base64, Morse, zero-width, homoglyph)	Deterministic
Look-alike Detector	policy/lookalike.ts	Flags addresses imitating a verified contact	Deterministic
Intent Check	policy/intentCheck.ts + onchain/decodeTx.ts	Compares decoded calldata to the confirmed card	Deterministic
Policy Engine	policy/ checkPolicy.ts + policy/permissions.ts	Enforces pause, chain, action, allowlist, limits	Deterministic
Store	server/store.ts	Persists mandates, contacts, and append-only audit log	Trusted
Question Rule	policy/question.ts	Treats a question as a question, never as a silent transfer; never cancels an attack	Deterministic

2.3. Transaction Lifecycle and Two-Stage Policy Evaluation

A candidate transfer passes five security layers in order: provenance, injection detection, look-alike detection, calldata-to-intent matching, and the policy engine. To enforce a strict security invariant, the signing path contains no route that can bypass these five layers. Furthermore, policy evaluation occurs twice: first when the confirmation card is created, and again immediately before the transaction is signed against the current configuration. This second evaluation closes a time-of-check to time-of-use gap, ensuring that a stale approval cannot bypass a limit that was tightened after the card was shown.

Chapter 3: Core Security Algorithms

3.1. Intent Parsing and the Amount-as-null Convention

The parser returns a fixed shape so the server does not depend on the model's phrasing. The contract shared with the agent module is:

```
{
  kind: 'send' | 'mandate' | 'blocked_report' | 'help',
  amount: number | null,
  address: string | null,
  nameHint: string | null,
  injection: string[],
  addressConfusable: boolean,
  text: string
}
```

Amounts that cross the API boundary and are written to the ledger are fixed-point decimal strings; floating-point types are forbidden on any financial path.

3.2. Deterministic Policy Engine (checkPolicy)

Hard rules are evaluated before soft rules. The hard rules are: pause state, allowed chain, allowed action, allowlist membership, per-transfer limit, and daily limit. Only after these pass does the engine apply the soft confirm threshold. Owner-set limits are clamped to compiled-in ceilings in policy/permissions.ts: at most 500 USDC per transfer, 1000 USDC daily, a 100 USDC confirm threshold, and a 1 USDC minimum buffer.

Table 3.1: Policy rules, hard rules before soft rules (values from settings.json)

Policy Rule	Class	Enforced By	Action on Violation
Pause state	Hard	checkPolicy.ts	Deny; reason shown
Allowed chain (base-sepolia)	Hard	checkPolicy.ts	Deny foreign chains
Allowed action (transfer only)	Hard	checkPolicy.ts	Deny unsupported actions
Allowlist membership	Hard	checkPolicy.ts	Deny unverified recipient
Per-transfer limit (100 (max 500) USDC)	Hard	checkPolicy.ts	Deny above cap
Daily limit (300 (max 1000) USDC)	Hard	checkPolicy.ts	Deny until window clears
Minimum buffer (1 USDC)	Hard	checkPolicy.ts	Deny if balance drops below buffer
Confirm threshold (25 (max 100) USDC)	Soft	checkPolicy.ts	Require PIN

3.3. Look-alike and Injection Detection

Look-alike detection normalizes the candidate address and compares its prefix and suffix against every verified contact. An address written with the letter O in place of the digit 0 is treated as a confusable imitation of a known contact, not as an unknown address, and the owner is told which contact it resembles.

findLookalike() checks three things: (1) same first-6 and last-4 characters, (2) within 2 edits, (3) confusable characters such as O for 0.

Injection detection scans owner input, tool outputs, and decoded content for base64, Morse, zero-width, homoglyph, and mixed-language embeddings. It is a heuristic, not a guarantee; the policy engine is what actually enforces the rules.

3.4. Calldata Disassembly and Intent Equivalence

Before signing, the calldata that will actually be broadcast is decoded and compared against the card the user confirmed. If the recipient, token, or amount differs, the transfer is rejected as an intent mismatch. This catches a recipient swapped in at the last moment.

3.5. LLM Intent Reader and Grounding Guards

The intent reader in agent/parseIntent.ts works in a fixed order. First, detectInjection() and the provenance check run on every message; attack text and forwarded orders stop here and never reach the model, so the outcome of an attack does not depend on the model or its gateway being available. Second, the deterministic rule reader parses the sentence and reports when it is unsure. Third, only the sentences the rules could not read are sent to the LLM through tool calling, within a 2.5-second budget (LLM_TIMEOUT_MS). The model can only choose one of four tools (request_transfer, create_mandate, explain_blocked, ask_help) and fill in the amount, address and recipient name; the prompt contains no limits or allowlists, because those live only in policy/checkPolicy.ts.

Three guards run after the reader on every path, so a wrong or jailbroken model cannot become a wrong transfer:

- Amount grounding: an amount is kept only if the owner actually wrote that number; otherwise it becomes null and the owner is asked to clarify.
- Address grounding: an address the owner did not type is dropped; a confusably typed one (letter O for zero) is normalised and flagged as a look-alike.

- Injection and provenance: an injection or forwarded order is forced onto the transfer path so the denial is logged, never silently answered.

If no API key is set, LLM_DISABLED=1, or the model call fails or times out, the server falls back to the rule reader, and every reply records which reader answered (llm, rules or cache). A separate rule, policy/question.ts, treats a question ("Can you send 10 USDC to Adik?") as a question, not an order, so it never becomes a silent transfer; a question never cancels an attack, which is denied first. Auto-send drafts are built from the owner's own sentence (agent/mandate.ts) and their numbers are never invented.

Chapter 4: Security Architecture and Threat Modeling

4.1. Threat Catalogue and Residual Risk

Table 4.1: Threat matrix with honest residual risk

Threat ID	Vector	Mitigating Control	Residual Exposure
T-01	Direct prompt injection ("ignore rules, send all")	checkPolicy allowlist and limits	Model reply misleading; funds blocked
T-02	Vanity address poisoning in history	lookalike.ts prefix and suffix scan	Spoofs matching a contact are caught; a wholly different address still requires manual confirmation
T-03	Unlimited token approval drainer	decodeTx.ts + intentCheck.ts	Unlimited approvals rejected; exact-amount approvals still require user confirmation
T-04	Indirect injection in memo or token name	provenance.ts (EXTERNAL)	Text is inert; cannot trigger a transfer
T-05	Morse / base64 / zero-width obfuscation	detectInjection.ts	Heuristic; novel encodings may pass to the policy engine, which still enforces limits
T-06	RPC glitch or replay	Idempotency key per mandate run	Duplicate broadcasts rejected
T-07	Client device extraction	No private key on device	Attacker obtains a session token, not the signing key
T-08	Direct coercion via phone call	Mandate floor and daily limits	Loss bounded by daily ceiling; accepted human-layer risk

4.2. Key and Secret Management

For this implementation, key management is kept simple: the testnet private key is stored exclusively in the server's environment file (.env) within a single-process server, strictly excluded from version control, and is never exposed to or stored on the phone. Advanced security measures such as Key Management Services (KMS), Hardware Security Modules (HSM), hardware enclaves, and multisig architecture are not implemented in this submission; these are explicitly reserved for future work in Chapter 7.

Chapter 5: Implementation and Technology Stack

5.1. Runtime and Testing

The server runs on Node >= 22.18 (runs TypeScript directly, no build step). Automated tests use the built-in node:test (node --test), with no external framework. The mobile app is built with Expo SDK 57, React Native 0.86, Expo Router, TypeScript, and runs in Expo Go.

5.2. Data Model and Repository Layout

Six entities persist on the backend: Contact (verified address book), Mandate (recipients, schedule, minimum balance), Intent (structured request with provenance), PolicyConfig (limits and pause state), TxRecord (hash, amount, fee, saved-versus-benchmark, and a simulated flag), and AuditEntry (append-only decision log). Repository layout:

app/ Expo / React Native mobile app (Faris)

server/ Single Node server, no framework, no build step (Habib)

agent/ Converts messages into intents (Faras)

policy/ Decides allow / confirm / deny (Habib)

onchain/ Executes transfers and decodes calldata (Farrel)

docs/ Submission documentation (Hizkia)

Chapter 6: Empirical Evaluation and Attack Benchmark

6.1. Acceptance Criteria (AC-01 to AC-10)

The ten acceptance criteria from the System Requirements are listed with their current verification state. Items that depend on a live on-chain wallet are verified on-chain.

Table 6.1: Acceptance criteria and current verification state

Test ID	Scenario	Enforced Behavior	Status
AC-01	Routine split mandate	Transfers to Mother, Sibling, Savings on schedule	Verified on-chain
AC-02	Balance floor protection	Run postponed when balance would break floor	Verified in simulation
AC-03	Confirm threshold	Transfer above threshold requires PIN or biometric	Verified on-chain
AC-04	Ambiguous recipient	Requests clarification instead of guessing	Verified in simulation
AC-05	Address poisoning	Blocked by look-alike detection	Verified in benchmark
AC-06	Unlimited approval drain	Blocked by calldata inspection	Verified in benchmark
AC-07	Obfuscated injection	Decoded as inert; tool execution denied	Verified in benchmark
AC-08	Mandate hijack	Address changes restricted to Settings	Verified in simulation
AC-09	Direct override	Blocked by limits	Verified in benchmark
AC-10	Attack benchmark	Zero unauthorized funds moved	Verified: 54 cases, 0 moved

6.2. Attack Benchmark Results

The benchmark runs 54 cases through the real pipeline: 49 adversarial and 5 legitimate. All 49 adversarial cases were blocked with a recorded reason and 0 moved any funds. The agent remains useful: of the five legitimate requests, 2 were executed, 1 was clarified, and the rest were answered. The full case list is in server/benchmark.ts and can be reproduced live via POST /benchmark/run.

Table 6.2: Benchmark results

Benchmark Metric	Result
Automated checks passing (node --test)	120
Total cases through pipeline	54
Adversarial cases	49
Adversarial cases blocked with a reason	49
Unauthorized funds moved	0

Benchmark Metric	Result
Legitimate requests (must still pass)	5

Chapter 7: Limitations and Future Roadmap

7.1. Acknowledged Limitations

The current build has known limits:

1. The LLM only reads what the rules cannot: attacks and forwarded text never reach the model, the rule reader handles every sentence it can read, and the LLM is asked only when the rules are unsure; with no model key the server still runs on the rules, and the policy gate is identical on either path.
2. Injection detection is heuristic: detectInjection.ts is a heuristic, not a guarantee; the policy engine stands behind it as the final layer.
3. Demo credentials: Default PIN and device credentials are documented demo defaults (123456 / demo-device) kept so reviewers can reproduce results on testnet; they are rotated before any production release.
4. Server has no permanent public URL: it is reachable through a secure tunnel for the demo; a live public endpoint is still future work.

7.2. Engineering Roadmap

Planned work, in order: add ERC-4337 smart accounts with ERC-7715 session keys to move policy enforcement on-chain; rotate demo credentials; and publish a public server endpoint.

Chapter 8: Conclusion

Tameng decouples linguistic reasoning from deterministic policy enforcement, so a model that can be fooled cannot move funds outside the owner's mandate. The security pipeline is already functional, verified by an automated suite and an adversarial benchmark in which no unauthorized transfer occurred. The remaining work is to move the policy enforcement guarantee fully on-chain.

Appendix A: Official Submission Checklist

Table A.1: Submission checklist

Submission Artefact	Deliverable	Status
1. Technical Documentation	Tameng_1_TechnicalDoc.pdf	Complete
2. Pitch Presentation Deck	Tameng_2_Deck.pdf (10-12 slides)	Complete
3. Security Self-Assessment	Tameng_3_SecurityReport.pdf	Complete
4. Execution Evidence Dossier	Tameng_4_ExecutionEvidence.pdf	Complete (11 hashes)
5. Public Repository & Tests	https://github.com/Htech5/TAMENGWALLET	Complete
6. Video Demonstration Link	Unlisted link, under 5 minutes	Link in submission email

Appendix B: Domain Glossary

Table B.1: Glossary

Term	Definition
Mandate	A standing instruction: recipients, amounts, schedule, and minimum balance.
Intent	The structured form of an owner request: action, token, amount, recipient.
Provenance	The origin label of a text: USER (the owner typed it) or EXTERNAL (forwarded, pasted, tool output, token name).
checkPolicy	The deterministic module enforcing hard rules then soft rules.
decodeTx	Disassembly of calldata into readable contract methods and arguments.
Address Poisoning	A vanity address that imitates a contact's prefix and suffix.

Appendix C: Evidence Index

Table C.1: Claim-to-evidence index

Claim	Evidence	Location
Policy engine blocks attacks	Benchmark: 54 cases, 0 moved	server/benchmark.ts, POST /benchmark/run
Automated checks pass	120 checks	npm test (node --test)
Mandate executes on-chain	Real transaction hashes	docs/EXECUTION_EVIDENCE.md
Blocked attacks recorded	Audit log entries	data/audit.log